



Journalisation



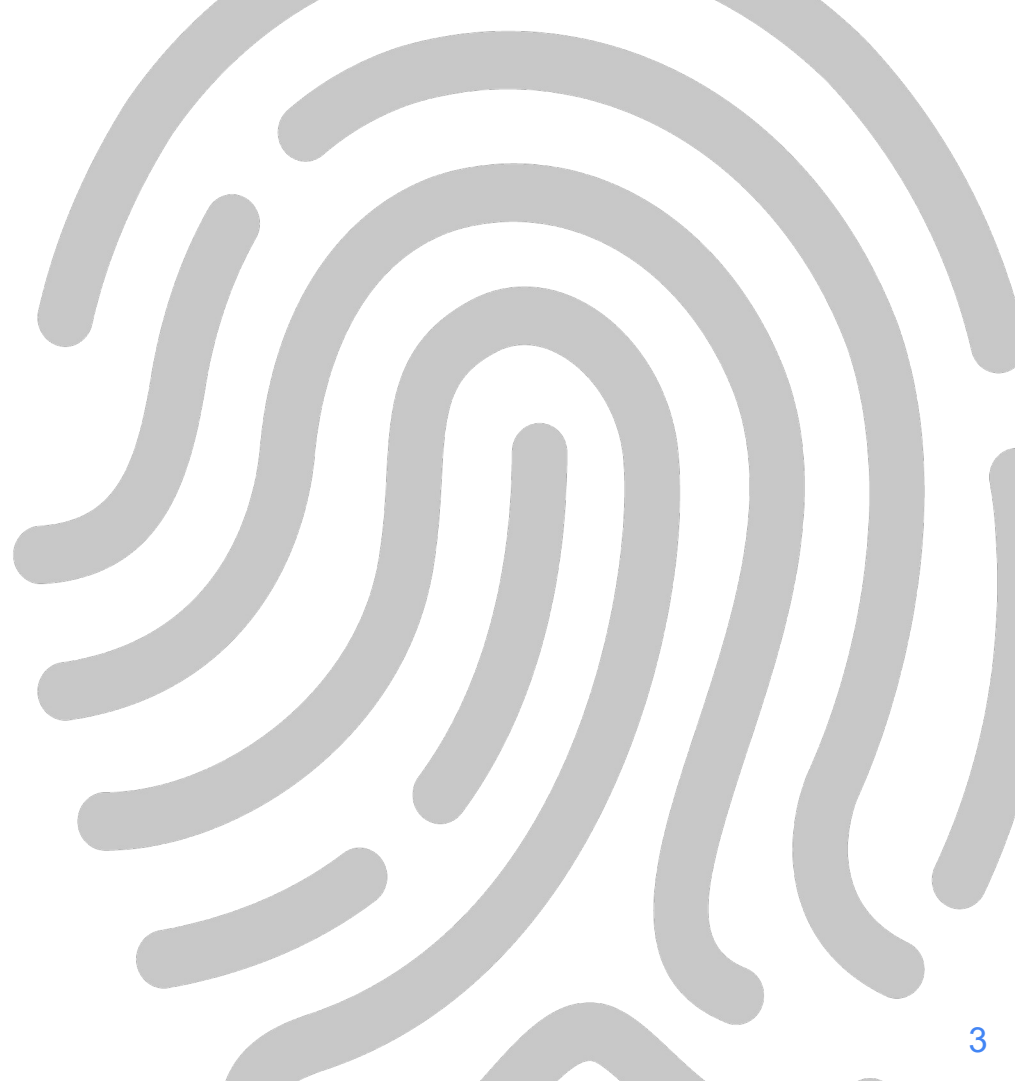
Quizz

Qu'est-ce qu'un journal ?



Plan

- 1 - [Introduction](#)
- 2 - [Journalisation GNU/Linux](#)
- 3 - [Journalisation Windows](#)





Introduction



Les journaux

Les applications (surtout serveurs) et les systèmes d'exploitations enregistrent des traces de leur activité.

=> Journaux d'événements ou logs.

Ces journaux :

- peuvent prendre différentes formes (fichiers, base de données);*
- peuvent avoir différents formats*

=> Choix des développeurs de l'application



Usage des logs

Pour les développeurs :

- *Découvrir les causes d'un bug*

Pour les administrateurs :

- *Comprendre les dysfonctionnements*
- *Analyser l'utilisation*

Pour la cybersécurité :

- *Voir des tentatives d'intrusion*



Historique

Idéalement : les journaux de chaque application devraient être complètement analysés en temps réel...

Dans la pratique, il est nécessaire de conserver de l'historique :

- *Permettre l'analyse d'événements passés*
- *Faire des déductions sur une suite d'événements pas nécessairement consécutifs*



Pertinence

Quelles sont les informations pertinentes à journaliser ?

- *Dépend de l'usage*

Ex :

- *Analyse cybersécurité : échecs de connexion, requêtes invalides...*
- *Administrateur : anomalies de fonctionnement, pannes...*

Besoin de catégoriser les informations et ajuster le niveau



Journalisation et obligations légales

Cadre réglementaire :

- *RGPD (art. 32)*
- *Loi de programmation militaire (LPM)*
- *Cadre métier (paiement, HDS)*
- *Information de sécurité (audit authentication ok/nok, etc.)*

Attention à :

- *Durée de conservation*
- *Protection*



Stockage & archivage

*Enregistrement de "toute" l'activité peut vite prendre beaucoup de place
Surtout en cas de dysfonctionnement => emballement.*

*La conservation de l'historique est un compromis avec les capacités de
stockage.*

Utilisation de techniques d'archivage et de compression.

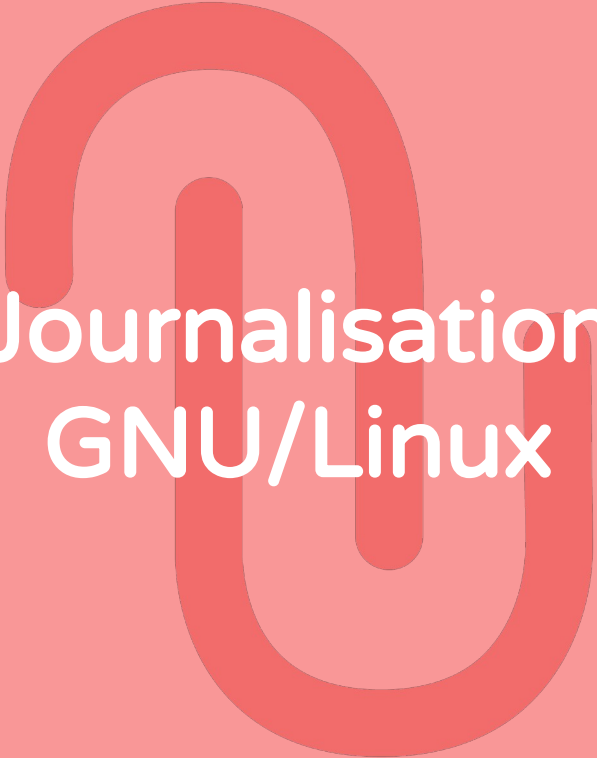


Standardisation et centralisation

Analyser et comprendre des journaux peut-être une tâche délicate

Points de difficultés :

- *Emplacements des journaux*
=> *Centralisation*
- *Format*
=> *Standardisation*



Journalisation GNU/Linux



Syslog

Développé pour [Sendmail](#) dans les années 80 par [Eric Allman](#)

Séparation de

- Générateur de messages
- Stockage de messages
- Analyseur de messages

Système client-serveur avec protocole de communication

Standard IETF : [RFC 5424](#)

514/UDP (non-sécurisé), 514/TCP, ou 6514/TCP (syslog over TLS)





Les messages

Les messages syslog

- *Date*
- *Hôte émetteur du message*
- *Service/Processus émetteur du message*
- *Identifiant de processus*
- *Identifiant de type de message*
- *Priorité correspond à Catégorie et Niveau de sévérité*
- *Message textuel*

Plus d'info : [Syslog sur WikipediA](#)



Les catégories

Syslog définit 24 catégories de messages numérotées de 0 à 23

Les 8 dernières (16 à 23) sont réservées pour un usage local non défini dans la norme.



Les catégories

Code	Mot-clé	Description
0	kern	messages du noyau
1	user	messages de l'espace utilisateur
2	mail	système de messagerie
3	daemon	services
4	auth	messages d'authentification
5	syslog	messages internes syslogd
6	lpr	messages d'impressions
7	news	messages d'actualités



Les catégories

Code	Mot-clé	Description
8	uucp	messages UUCP
9	cron	tâches planifiées (at/cron)
10	authpriv	sécurité / élévation de privilèges
11	ftp	logiciel FTP
12	ntp	synchronisation du temps NTP
13	security	log audit
14	console	log alert
15	solaris-cron	tâches planifiées (at/cron)



Les 8 niveaux de gravité

Code	Gravité	Mot-clé	Description
0	Emergency	emerg (panic)	Système inutilisable.
1	Alert	alert	Intervention immédiate nécessaire.
2	Critical	crit	Erreur critique pour le système.
3	Error	err (error)	Erreur de fonctionnement.
4	Warning	warn (warning)	Avertissement (sans intervention une erreur peut survenir).
5	Notice	notice	Événement normal méritant d'être signalé.
6	Informational	info	Pour information.
7	Debugging	debug	Message de débogage.



Envoyer un message

Une application peut envoyer des messages syslog en se basant sur des appels systèmes.

En python : [bibliothèque syslog](#)

*Avec bash (interactif ou script) : **logger** (voir **man logger**)*



Stocker les messages

Le stockage de message est assuré par un daemon syslog ([rsyslog](#))

- *Stockage fichiers dans /var/log/* (par défaut)*
- *Filtrage par catégorie et sévérité :*
 - *auth => /var/log/auth.log*
 - *kern => /var/log/kern.log*
 - *...*
- *Stockage possible en base de données (postgresql, mysql, etc.)*
- *Transmission à serveur syslog distant*



Configuration client syslog

Utiliser rsyslog (modifier /etc/rsyslog.conf).

Toujours privilégier TCP sur UDP (garantie de livraison).

Utiliser TLS pour chiffrer les logs en transit.

Filtrer les IP sources autorisées (pare-feu).



Archiver les journaux

logrotate est une commande installée par défaut

- *Pour éviter de surcharger les disques de journaux*
- *Exécutée régulièrement par cron*
- *Archive et compresse puis supprime les anciens log*
- *Peut aussi envoyer les logs par mail avant suppression*

Voir : man logrotate et man cron



Consulter les journaux

Commandes utiles pour consulter les logs :

- *cat, more, less, zcat, zmore, zless : consultation en entier*
- *head, tail : consultation en partie*
- *grep, zgrep : recherche par filtre*
- *watch : exécution périodique de commande*
- *dmesg : Cas particulier des logs du noyau*
- *last, lastb : Cas particulier login/out utilisateurs et échec*



Systemd

Systemd propose lui aussi un système de journalisation

- *Stockage au format binaire (/run/systemd/journal)*
- *Outil de consultation : journalctl*
- *Mécanisme de rotation interne*
- *Peut transmettre à syslog (compatibilité)*



Analyse de logs

Pour automatiser le traitement des logs

- [logwatch](#)
- [Graylog](#)
- [LogAnalyzer](#)

En allant plus loin :

- Outils de supervision
- [SIEM - Security Information and Event Management](#) et HIDS



Journalisation Windows



Observateur d'événements

L'observateur d'événements (*event viewer*) est le journal dans lequel toute l'activité de Windows est enregistrée :

- Information simple
- Enregistrement d'erreurs de fonctionnalités

Il est nativement disponible sur les OS serveurs et clients.

*Les fichiers de log sont dans **C:\Windows\System32\winevt\Logs***

A partir d'une console on peut avoir accès aux événements locaux ou distants.



Accès à l'évent viewer

- Touche Windows + R
- Commande **eventvwr** dans une console
- Icône "Observateur d'événements" dans les outils d'administration
- Lien "Event viewer" dans le Server Manager (serveur)



Contenu

Les journaux sont répartis en :

- *Affichages personnalisés ⇒ création de vues personnalisées*
- *Journaux Windows ⇒ OS*
- *Journaux des applications et des services ⇒ Applicatifs et autres*
- *Abonnements ⇒ centralisation des logs*

On trouvera :

- *Les erreurs*
- *Les messages d'informations*
- *Les alertes*



Centralisation

Windows Event Forwarding (WEF) :

Collecter les événements de plusieurs machines Windows vers un collecteur central.

1 serveur reçoit les logs des autres serveurs, protocole : WinRM (HTTP/5985 ou HTTPS/5986).

Gestion par GPO possible.



Centralisation (suite)

Événements à centraliser (minimum) :

- 4624, 4625 (Authentification)
- 4740 (Verrouillage de compte)
- 4728, 4732, 4756 (Modifications de groupes)
- 1102 (Suppression des journaux)
- 4663 (Accès objets sensibles)



Niveau de criticité et event ID

Il y a 3 niveau de criticité :

- *High*
- *Medium*
- *Low*

L'event ID est le code du type d'événement.



Quelques event ID intéressant

- 4624 : *logon normal avec succès*
- 4625 : *logon avec erreur de connexion*
- 4740 : *compte verrouillé*
- 4728 : *ajout d'un utilisateur à un groupe de sécurité global*
- 4732 : *ajout d'un utilisateur à un groupe de sécurité local*
- 4756 : *ajout d'un utilisateur à un groupe de sécurité universel*
- 4663 : *tentative d'accès à des objets*
- 1102 : *suppression des journaux*



Analyse de logs

*En plus des outils d'analyse de logs, on est parfois obligé de faire du **parsing** de log (analyse de contenu de logs).*

*Les **regex** (expressions régulières) peuvent aider à l'automatisation du parsing de logs.*



En conclusion

Les journaux sont les yeux des admin sur l'activité de leur SI
Apprendre et les lire est indispensable
Organiser leur collecte et leur stockage pour ne pas les perdre

Pour aller plus loin

Principes, outils et protocole de supervision

Analyse de logs :

- *HIDS*
- *Outils SIEM & [SOC](#)*